

SIMATS ENGINEERING ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Report Analysis Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**
2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks. **(20 Marks)**
3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure. **(10 Marks)**

Code of Conduct:

I A.Poojitha(192511230) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Question 1 — Nmap Scan Report Analysis (20 Marks)

A security analyst performed a network scan on target 192.168.1.10 using Nmap, revealing open ports HTTP (80), SSH (22), and MySQL (3306), along with OS and service version details.

1.1 Sample Scan Command and Report

CODE:

```
$ nmap -sV -O -p- 192.168.1.10
```

```
Starting Nmap 7.94 ( https://nmap.org )  
Nmap scan report for 192.168.1.10  
Host is up (0.0021s latency).
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux)
80/tcp	open	http	Apache httpd 2.4.29 ((Ubuntu))
3306/tcp	open	mysql	MySQL 5.7.33-0ubuntu0.18.04.1

```
OS details: Linux 4.15 - 5.6 (Ubuntu 18.04)
```

```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

EXPLANATION

The Nmap scan was performed on the target IP address 192.168.1.10 to identify open ports, running services, service versions, and the operating system. The report shows that the target system is active and responding to network requests.

- Port 22 (SSH) is open and running OpenSSH 7.6p1. SSH is used for secure remote login and server administration. If weak passwords or outdated software are used, attackers may gain unauthorized access.
- Port 80 (HTTP) is open and running Apache HTTP Server 2.4.29. This indicates that the system is hosting a website. An outdated web server may contain vulnerabilities that attackers can exploit to access or damage the website.
- Port 3306 (MySQL) is open and running MySQL 5.7.33. This port is used for database services. If the database is not properly secured, attackers may steal, modify, or delete sensitive data.
- The Operating System Detection shows that the target is running Ubuntu Linux 18.04 with a Linux kernel version between 4.15 and 5.6. This information helps administrators identify the system, but it can also help attackers search for known vulnerabilities in that OS version.

Question 2 — Phishing Awareness Campaign Analysis (20 Marks)

A GoPhish phishing simulation run against ABC Technologies Pvt. Ltd. employees found that 40% clicked the phishing link, 20% entered login credentials, and several users downloaded a malicious attachment.

Sample Campaign Report

GoPhish Campaign Summary — "Q3 Password Reset Notice"

```
-----  
Total Emails Sent      : 200  
Emails Opened          : 120    (60%)  
Link Clicked           : 80     (40%)  
Credentials Submitted  : 40     (20%)  
Attachment Downloaded  : 22     (11%)  
  
Reported as Suspicious : 15     (7.5%)
```

EXPLANATION

The GoPhish report shows the results of a phishing awareness campaign conducted for employees of ABC Technologies Pvt. Ltd. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several employees downloaded a malicious attachment. These results show that many employees were unable to identify phishing emails, making the organization vulnerable to social engineering attacks.

- 40% clicked the phishing link: This indicates that a large number of employees trusted the fake email without verifying its authenticity. Clicking malicious links can redirect users to fake websites or download malware.
- 20% entered their login credentials: This is a serious security risk because attackers can steal usernames and passwords, leading to unauthorized access to company accounts and sensitive information.
- Several employees downloaded malicious attachments: Downloading infected files can install malware or ransomware, which may damage systems, steal data, or disrupt business operations.

Question 3 — DNS Zone Transfer (AXFR) Analysis (10 Marks)

A DNS assessment using the dig tool found that the organization's DNS server permits a successful zone transfer (AXFR), exposing internal hostnames, mail servers, and DNS records to an unauthenticated requester.

Sample Assessment Command and Report

```
$ dig axfr example.com @ns1.example.com

; <<>> DiG 9.18.1 <<>> axfr example.com @ns1.example.com
;; global options: +cmd
example.com.      3600  IN  SOA  ns1.example.com. admin.example.com. ...
example.com.      3600  IN  NS   ns1.example.com.
example.com.      3600  IN  MX   10 mail.example.com.
www.example.com.  3600  IN  A    192.168.1.10
vpn.example.com.  3600  IN  A    192.168.1.15
hr-internal.example.com. 3600  IN  A    10.0.5.22
db-prod.example.com. 3600  IN  A    10.0.5.40
;; Query time: 42 msec

;; XFR size: 24 records (messages 1, bytes 812)
```

EXPLANATION

The Dig tool was used to assess the organization's DNS server. The report shows that the DNS server allows a DNS Zone Transfer (AXFR), which exposes important DNS information such as internal hostnames, mail servers, and DNS records. This is a serious security issue because attackers can collect detailed information about the organization's network.

- **DNS Zone Transfer (AXFR):** A zone transfer is used to copy DNS records between DNS servers. If it is not restricted, unauthorized users can access the entire DNS database.
- **Exposure of Internal Hostnames:** Attackers can identify internal servers and devices, making it easier to target critical systems.
- **Exposure of Mail Servers:** Knowing the mail server details allows attackers to launch phishing attacks, email spoofing, or spam campaigns.
- **Exposure of DNS Records:** DNS records reveal the organization's network structure, helping attackers plan further attacks or exploit vulnerable systems.

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.